

TECHNICAL SECURITY SPECIFICATIONS FOR
SERVER WINDOWS

AUTHOR(S) : Said Rakkabi
VERSION : 6.9
STATUS : Final
SOURCE : Atos
DOCUMENT DATE : 28 October 2021
NUMBER OF PAGES : 49

OWNER : IMAD ELFACHTALI

Role	Approval
Global Service Architect	Sameer Mhatre
Quality Assurance Function	Srimathy Desabhatla
AHS Operational Security and Compliance Officer	Kamil Kilinski
Head of Risk Management and Control Framework	Jayesh Suryavanshi (on behalf of Dorin Vlas)

Contents

1	General Information	9
1.1	Purpose	9
1.2	Audience	9
1.2.1	Scope	9
1.3	Implementation of measures	9
1.4	Document maintenance and distribution	10
1.5	Related documents	10
2	Introduction	11
2.1	Risk Classifications.....	11
2.2	Deviations	11
3	Description of Measures.....	12
3.1	Authorization and Authentication	12
3.2	Network Security	21
3.3	Operation Security	27
3.4	Logging	38
3.5	Non-Alcatraz Measures	44
Appendix A	Checklist	47

List of changes

version	Date	Description	Author(s)
0.1	21-03-2014	Initial version	Michael Young
0.2	14-04-2014	Changed measure tables	Patrick Holt
0.3	15-05-2014	Added implementation steps, classifications, and reference docs.	Michael Young
1	19-05-2014	Final version	Patrick Holt
1.1	18-07-2014	Changes made during creation of scripts, Removed measure #00074	Michael Young
1.2	19-12-2014	Added variable field to measures	Patrick Holt
1.3	27-01-2015	Changed variable field into exception field	Patrick Holt
1.4	02-02-2015	Changed Senior Manager Atos name to David Bixler	Patrick Holt
2	23-03-2015	Final version	Patrick Holt
2.1	05-06-2015	Removed signature line for Global Tower Head	Patrick Holt
2.2	30-06-2015	Changed measures to address "over-compliance" findings: #00006, #00007, #00008, #00014, #00023, #00034, #00040: added or less #00013, #00015, #00016, #00018: added or greater #00021: added or greater	Patrick Holt / Michael Young
2.3	16-07-2015	Adjusted measures: #00006: added non-zero value #00007: added non-zero value #00034: added extra Windows 2012 section #00052: added extra Windows 2003 section #00060 - #00070: added background info	Patrick Holt / Michael Young
2.4	21-09-2015	Added extra text to section 1.4: "All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer."	Patrick Holt
2.5	13-10-2015	- Added extra section "Document maintenance and distribution" - Removed all references to MSM-GSS-0008 - Changed GSS to BDS in the whole document	Patrick Holt
3	09-11-2015	Final version	Patrick Holt
3.1	02-12-2016	3SW00014 - Added "a non-zero value" to the value setting 3SW00074 - Added User Password: Age Minimum 3SW00075 - Added Administrator/Service Password: Length 3SW00076 - Service Hardening: SNMP Community Names	Iain Lavery
3.1.1	19-06-2017	3SW00016 - Updated to 24 passwords or above to align to Microsoft Security best practice	Iain Lavery

3.1.2	24-06-2017	3SW00075 –Administrator password length updated to reflect Microsoft standard 3SW00006 Password Age: Updated to Microsoft standard. 3SW00007 User Password: Age Maximum: Updated to Microsoft standard. 3SW00077 Server Hardening: disabling SMB1 standard added	Iain Lavery
3.1.3	24-01-2018	Updated signature field "Role" "Global Service Architect" to "Document Owner" to fulfill the requirements of "Atos document control".	M. Weise
3.1.4	15-04-2019	Reverse changes to 3SW00007 – Changed back to Atos policy of 90 days 3SW00016 – Changed back to Atos policy of 5 previous passwords or more. Updated each measure to remove the numeric risk classification.	R. Roche
3.1.5	15-04-2019	Reverse changes to 3SW00007 – Changed back to Atos policy of 90 days 3SW00016 – Changed back to Atos policy of 5 previous passwords or more. Updated each measure to remove the numeric risk classification.	R. Roche
3.1.6	15-04-2019	Template alignment	M. Zabrocka
3.1.7	16-05-2019	Unsupported OS version 2003 removed from SCOPE SW00007: Updated background text and reference SW00010: Updated measure text to include PIN compliancy. SW00014: Value update SW00015, SW00020, SW00023, SW00024, SW00047 Updated baseline reference SW00054: Updated Value SW00075: Updated Reference, Updated Character value to 15 SW00078: Added new measure to include Virus	A. El Hamzaoui, Robert Roche
4	17-05-2019	Final Quality assurance.	M.Zabrocka K.Cieslak- Rylich

4.1	05-07-2019	Review	M. Zabrocka, H. Pechholz, A. El Hamzaoui
4.2	23-07-2019	Changes: SW00007 – maximum age restored for 90 days, Baseline reference update SW00010 – background description changed, excluded PIN from description SW00014 – value changed in implementation field SW00018 – value changed for 15, Baseline reference update Create separate section for Non-Alcatraz measures (chapter 3.5) New measure SW00079 for PIN parameters and measure transferred to chapter 3.5 SW00075 – changed for user account credentials, value changed for password length, Baseline reference update and measure transferred to chapter 3.5 SW00078 – description changed and transferred to chapter 3.5 New measure SW00080 for system account only with new value for maximum password age and measure placed into chapter 3.5	M. Zabrocka
4.3	23-07-2019	Review: SW00006 – added recommended value	A. El Hamzaoui
4.4	02-08-2019	SW00052 – Windows 2003 recommendation deleted (system unsupported) SW00074 – deleted (covered by SW00007) Checklist update	M. Zabrocka
4.5	28-08-2019	SW00018 value changed for 8 characters SW00075 value changed for 15 characters Alcatraz Team review	M. Zabrocka, H. Pechholz
4.6	04-09-2019	SW00015 – values changed for '15 or more, but less than 30' SW00019, SW00059 & SW00078 transferred to Non-Alcatraz measures SW00034 value changed for '900 seconds or less (but more than 0)' SW00040 value changed for '15 minutes or less (but more than 0)' SW00076 and SW00077 – transferred under Network chapter (3.2)	M. Zabrocka
5	08-10-2019	SW00027 - implementation description minor change SW00079 – implementation description changes. SW00034 – implementation description changed (no impact for Alcatraz scanner, point one removed) SW00074 – restored Quality assurance, final version.	M. Zabrocka Katarzyna Cieslak-Rylich
5.1	26-11-2019	Quality assurance, final version. Final	M. Zabrocka

5.2	04-06-2020	New measures: 3SW00080 Service Account – Maximum Age 3SW00081 Windows: Domain Member must be running Credential Guard 3SW00082 Windows: Create a token object user right must not be assigned to any groups or accounts	Kashif Baig
5.3	20-07-2020	removed legacy windows OS i.e. 2008/2008r2 entries from 1.2.1 Scope 3SW00052 Updated with new patch 3SW00075 Updated, by removing Legacy OS entries from implementation section Baseline reference to Implementation section	Nizamuddin Shaikh
5.4	12-08-2020	Added Measure 3SW00083 Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2 & above.	Kashif Baig
5.4	31-08-2020	3SW00010 URL added and PIN reference	Ritesh Sinha
5.5	01-09-2020	Security Review	M. Zabrocka
5.6	02-09-2020	3SW00077 implementation description change	Kashif Baig
5.7	09-09-2020	Updates	Kashif Baig
5.8	10-11-2020	Measure 2SW00002 - added exception for IIS_USR	Kashif Baig
5.9	25-11-2020	Security review Measure ID prefix restored Changes table update Measure list update Moved measure 3SW00079 to chapter 3.1	M. Zabrocka
5.10	18-12-2020	Alcatraz review 2SW00060 – value changed for “at least Success” 3SW00003 – exception rephrased	M. Zabrocka
5.11	22-12-2020	Measure 3SW00082 moved to chapter logging Measure 3SW00079 moved to Non-Alcatraz Measures	M. Zabrocka
6.0	22-12-2020	Final Quality assurance	M. Gondek
6.1	04-05-2021	3SW00001 – Exception has been added 3SW00084 Measure has been Created under chapter 3.3 Operation Security for AppLocker usage and check for any executable files from Public Folders 3SW00027 (IRDP) – Updated implementation instruction 3SW00029 – Corrected headline 3SW00081 – Updated implementation steps 3SW00083 – Updated implementation steps	Vipul / Said
6.2	13-05-2021	Security review Changes in: measures 3SW00062, 3SW00064, 3SW00065, 3SW00066, 3SW00067, 3SW00068, 3SW00070 for “ <u>at least</u> ” – “Success”	M. Zabrocka
6.3	31-05-2021	Comments Review	Said
6.4	07-06-2021	Security Review	M. Zabrocka

6.5	07-06-2021	Comments Review	Vipul / Said
6.6	11-06-2021	3SW00086 Measure has been Created under chapter 3.3 Operation Security 3SW00085 Measure has been Created under chapter 3.3 Operation Security for to check all executable files in vulnerable locations exp. C:\Users\Public	Vipul / Said
6.7	24-06-2021	Security review	M. Zabrocka
6.8	24-06-2021	3SW00087 Measure has been created under chapter 3.2 Network Security	Vipul / Said
6.9	28-10-2021	Security review Modify 3SW00077 – registry key implementation removed Quality assurance	Said Srimathy

Target readers, communication method

Target group	Distribution / publication method
Designers, architects and administrators tasked with validation and implementation of the security baselines.	The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG) on SharePoint https://sp2013.myatos.net/ms/gd/gadp/TSSD/

1 General Information

1.1 Purpose

A Technical Security Specification (TSS) is a document that translates the high-level security controls contained in the Atos IDM Security Baselines into specific Technical Security Measures.

Each TSS documents the Technical Security Measures for the configuration of a specific device, application or operating system. These Measure are then validated for compliance using specifically developed scripts. That data is then used to generate compliance reports, and to drive remediation of deficiencies.

The document also details the Risk Classification, the data and data sources required for each Technical Security Measure.

1.2 Audience

This document is intended for designers, architects and administrators tasked with validation and implementation of the security baselines as per IT Control Framework (ITCF).

The document assumes that the reader has reasonable understanding of the Security Compliance Process as well as familiarity with the devices/software mentioned in this document.

1.2.1 Scope

The scope of this Technical Security Specification covers the following:

- ▶ Windows Server 2012, 2012 R2, 2016 and 2019

The following areas are explicitly out of scope:

- ▶ Windows Workstations

1.3 Implementation of measures

The implementation of the TSS measures is mandatory for all target devices and software mentioned in the scope. In case of implementation in existing environments, TSS measures must be tested first in pre-production test environments following applicable change management processes before implementation in production.

Some of the measures in this document may affect compliance to industry specific regulations. In this case the security officer must approve the implementation or create an exception.



All exceptions to measures mandated by this document must be registered in the Atos Risk Tool (ART) and must be agreed by the Client Security Manager and the Customer.

1.4 Document maintenance and distribution

The TSS document, when approved, published and validated, becomes procedural to all referenced systems, services, applications or processes managed by Atos Infrastructure & Data Management (I&DM) following a 120 days grace period, during which an analysis of gaps, documentation of exceptions, and a plan to bring non-compliant systems into compliance must be developed.

The maintenance of the document is performed by the Global Service Architect. TSS documents will be reviewed minimally on an annual basis, unless technical or business requirements dictate updating sooner.

1.5 Related documents

This document is a subset of Atos Technology Lifecycle Management (ATLM) artifacts. Related documents are captured in below table.

Reference	Document Name
MSM-GSS-0001	Security Management Baseline
MSM-GSS-0002	Logical Security Baseline
MSM-GSS-0006	Server Security Baseline
ASM-SEC-0006	ATOS INFORMATION SECURITY POLICY

Table 1: ATLM Related Documents

A number of vendor best practice documentation has been used in this TSS as per next table.

Vendor	Document Name
Microsoft	http://technet.microsoft.com
Microsoft Baseline Security	https://www.microsoft.com/en-us/download/details.aspx?id=55319

Table 2: Vendor documentation

2 Introduction

The “Technical Security Specifications for Server Windows” is a mandatory supplement to the existing Atos Security Policy and IT Security Controls. Its purpose is to increase security for IT systems, and it must be implemented for all Atos managed devices. The measures and their priorities described here may be tightened and supplemented as necessary.

The TSS documents are published by Atos Risk, Audit & Compliance Governance (RACG). The TSS itself is coordinated with reviewers from the Global Security Services and all relevant Atos Global Delivery units. It aims at providing sufficient detail to allow a qualified administrator to implement all measures.

To assist in documentation, a checklist for the manual validation process has been prepared as part of this TSS in appendix A. Further assurance about the compliance of a device or software to the Atos IT Security Controls can be gained via a Scan on Demand as part of the Vulnerability Management Service offered Atos Big Data & Security (BD&S).

2.1 Risk Classifications

Each confirmed measure is assigned a risk level (Critical, Moderate, or Low) corresponding to its potential impact on the security of Atos service delivery and devices/software in scope.

CRITICAL

A security control is critical if it can be exploited by a remote attacker to gain access to the system, data or functionality when not implemented. All critical controls must be implemented before the equipment is installed in a production environment.

MODERATE

A security control is rated moderate if it can compromise data or functionality on the network equipment only if some other condition is met (e.g. a particular module or a user within a particular role is required). Moderate issue security bulletins typically include recommended actions to resolve the issue.

LOW

A security control is rated low if it is very difficult to exploit from outside or has a limited potential impact.

2.2 Deviations

Deviations to the measures must be corrected according to customer agreed Service Level Agreements (SLA). Atos will use default resolution targets for correcting the deviations that must be confirmed or changed by each customer.

Because correcting a deviation may impact the customer’s business process, the analyst must decide whether or not the customer should be consulted. If the customer does not agree with correcting a deviation because doing so will negatively impact his business, a Risk Acceptance Form (RAF) has to be signed and handed over to formally transfer the associated risks to the customer. Atos will retain the right to accept or challenge the customer exception request.

3 Description of Measures

All measures in this document are categorized as MANDATORY. This categorization means that implementation is absolutely required. Exceptions to these measures must be registered in the Atos Risk Tool (ART) and approved by the CSM and Account Team.

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119 (<https://www.ietf.org/rfc/rfc2119.txt>).

All measures are grouped into specific areas. The specific areas are chosen to combine measures where the IT Security Control can be divided into multiple measures, e.g. "Updates and Patches", "User Management and Access Control" and "Protocols and Services".

3.1 Authorization and Authentication

Measure ID	3SW00001
Measure Title	Authorization: Administrative Delegation
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Enable computer and user accounts to be trusted for delegation.
Measure	Enable computer and user accounts to be trusted for delegation.
Implementation	For Windows, this is a Group Policy Object setting: 1) From the desktop, click Start button, Settings, Control Panel, Administrative Tools, Local Security Policy 2) In the console tree, click Security Settings. 3) Click Local Policies. 4) Double-click "Enable computer and user accounts to be trusted for delegation". 5) Ensure that it is left blank/empty
Exception	DC (Domain Controller) must have "Administrators" in the value of this setting and not to be empty
First appearance	19-05-2014

Measure ID	3SW00002
Measure Title	Authorization: Impersonation of Client
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Impersonate a client after authentication.
Measure	Impersonate a client after authentication.
Implementation	For Windows, this is a Group Policy Object setting: 1) Click Start, point to Programs, point to Administrative Tools, and then click Local Security Policy. 2) Expand Local Policies, and then click User Rights Assignment. 3) In the right pane, double-click Impersonate a client after authentication. 4) In the Local Security Policy Setting dialog box, click Add.

	5) In the Select Users or Group dialog box, click the user account that you want to add, click Add, and then click OK. 6) Click OK. Only the following users/groups are allowed: - Administrators - LOCAL SERVICE - NETWORK SERVICE - SERVICE
Exception	User/groups allowed if needed (if IIS is installed) IIS Users
First appearance	19-05-2014

Measure ID	3SW00003
Measure Title	Authorization: Server Shutdown
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Shut down the system.
Measure	Shut down the system.
Implementation	For Windows, this is a Group Policy Object setting: 1) Click Start, point to Programs, point to Administrative Tools, and then click Local Security Policy. 2) Expand Local Policies, and then click User Rights Assignment. 3) In the right pane, double-click "Shut down the system". 4) By default, many groups are defined here. Remove all accounts and groups which are not "Administrator" 5) In the Select Users or Group dialog box, remove any non-Administrator account, and then click OK. 6) Click OK. When done, only "Administrators" and "Backup Operators" groups must be enumerated here.
Exception	
First appearance	19-05-2014

Measure ID	3SW00004
Measure Title	Login: LDAP Client Signing
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Network Security: LDAP client signing requirements.
Measure	Network Security: LDAP client signing requirements.
Implementation	For Windows, this is a Group Policy Object setting: 1) Click Start, point to Programs, point to Administrative Tools, and then click Local Security Policy. 2) Expand Local Policies, and then click Security Options. 3) In the right pane, double-click "Network Security: LDAP client signing requirements." 4) Choose the option provided below.

	5) Click OK.
	Use Option: "Negotiate Signing"
Exception	
First appearance	19-05-2014

Measure ID	3SW00005
Measure Title	Login: Only Allow Local Console Access to Administrators
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Allow log on locally.
Measure	Allow log on locally.
Implementation	For Windows, this is a Group Policy Object setting: 1) Click Start, point to Programs, point to Administrative Tools, and then click Local Security Policy. 2) Expand Local Policies, and then click User Rights Assignment. 3) In the right pane, double-click "Allow log on locally". 4) By default many groups are defined here. Remove all accounts and groups which are not "Administrator" or Administrators 5) In the Select Users or Group dialog box, remove any non-Administrator account, and then click OK. 6) Click OK.
Exception	
First appearance	19-05-2014

Measure ID	3SW00006
Measure Title	Password: Age
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Domain Member: Machine account passwords must be changed at an interval of no more than 30 days.
Measure	Domain Member: Maximum machine account password age.30
Implementation	For Windows, this is a Group Policy Object setting: 1) Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\ 2) In the right pane, double-click "Domain Member: Maximum machine account password age" 3) Set the attribute to the value provided below. 4) Click OK. Source : https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/domain-member-maximum-machine-account-password-age Value: Between 1 and 30 days Recommended value = 30 days

Exception	
First appearance	19-05-2014

Measure ID	3SW00007
Measure Title	User Password: Age Maximum
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.15, 2.1.26 MSM-GSS-0006 – 2.4.8
Background	Passwords MUST have a validity period of no more than 90 days. If set passwords for system accounts should have a maximum password age of 1 year (365 days)
Measure	Maximum Password Age.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\" 2) Set the attribute to the value provided below. 3) Click OK. Value: A non-zero value less than or equal to 90 days
Exception	
First appearance	19-05-2014

Measure ID	2SW00008
Measure Title	Password: Cached Credentials
Classification	MODERATE
Baseline Reference	No reference to security baseline
Background	Ensure that a reasonable number of cached credentials are stored locally, in case central domain authentication is not available.
Measure	Test that "Number of previous logons to cache (in case domain controller is not available)" is set to 10 logins.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Interactive logon: Number of previous logons to cache (in case domain controller is not available)" and set it to the value provided below. Value: 10 logins or less
Exception	
First appearance	19-05-2014

Measure ID	3SW00009
Measure Title	Password: Changes for Machine Account

Classification	CRITICAL
Baseline Reference	No Security baseline reference
Background	Ensure domain controllers change passwords within a reasonable interval. Also ensure the proper password change interval is set as per control SW00006.
Measure	Domain Member: Disable machine account password changes.
Implementation	Source : https://docs.microsoft.com/en-ca/windows/security/threat-protection/security-policy-settings/domain-member-disable-machine-account-password-changes 3) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 4) Choose "Domain Member: Disable machine account password changes" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00010
Measure Title	Password: Complexity
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.6, 2.1.7, 2.1.8 MSM-GSS-0006 – 2.4.8
Background	Ensure that all passwords set must meet complexity requirements. These values are defined at the following URL: https://technet.microsoft.com/en-us/library/cc786468(v=ws.10).aspx
Measure	Password must meet complexity requirements. In the event a password is not possible, and a PIN is used instead, use of a compliant PIN is required (please refer to measure 3SW00079)
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy" 2) Choose "Password must meet complexity requirements" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00011
Measure Title	Password: Domain Authentication
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.19 MSM-GSS-0006 – 2.4.8, 2.4.9

Background	Ensure the newest authentication protocols are used for domain authentication. Older protocols are deemed insecure.
Measure	Network Security: LAN Manager authentication level.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\ 2) Choose "Network Security: LAN Manager authentication level" and set it to the value provided below. Value: Send NTLMv2 response only. Refuse LM & NTLM
Exception	
First appearance	19-05-2014

Measure ID	3SW00012
Measure Title	Password: Encryption
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.13 MSM-GSS-0006 – 2.4.8
Background	User passwords must not be stored in clear-text on the server.
Measure	Disable the "Store passwords using reversible encryption" control.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\ 2) Choose "Store passwords using reversible encryption" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00013
Measure Title	Password: Failure Lockout Duration
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.10 MSM-GSS-0006 – 2.4.8
Background	When an account is locked out due to repeated password violations, wait a certain amount of time before allowing further logon attempts.
Measure	Account Lockout Duration.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\ 2) Choose "Account Lockout Duration" and set it to the value provided below. Value: 30 minutes or more
Exception	
First appearance	19-05-2014

Measure ID	3SW00014
Measure Title	Password: Failure Threshold
Classification	CRITICAL

Baseline Reference	MSM-GSS-0002 – 2.1.10 MSM-GSS-0006 – 2.4.8
Background	Number of times incorrect credentials can be entered before the respective account is locked.
Measure	Account Lockout Threshold.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy" 2) Choose "Account Lockout Threshold" and set it to the value provided below. Value: A non-zero value less than or equal to 10 days
Exception	
First appearance	19-05-2014

Measure ID	3SW00015
Measure Title	Password: Failure Timer
Classification	CRITICAL
Baseline Reference	No security baseline reference
Background	After a certain amount of time, reset the lockout counter for the respective account.
Measure	Reset account lockout counter after this duration.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy" 2) Choose "Reset account lockout counter after this duration" and set it to the value provided below. Value: 15 or more, but less than 30
Exception	
First appearance	19-05-2014

Measure ID	3SW00016
Measure Title	Password Retention History
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.11 MSM-GSS-0006 – 2.4.8
Background	Enable a reasonable password retention policy. This measure ensures that passwords cannot be reused before a certain number of other passwords have been used.
Measure	Enforce Password History.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy" 2) Choose "Enforce Password History" and set it to the value provided below. Value: 5 passwords remembered or more.
Exception	

First appearance	19-05-2014
------------------	------------

Measure ID	3SW00017
Measure Title	Password: LAN Manager Hash Storage
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.5, 2.4.8
Background	Local SAM storage of the LM hash for a user's password must be disabled.
Measure	Network Security: Do not store LAN Manager hash value on next password change.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\". 2) Choose "Network Security: Do not store LAN Manager hash value on next password change" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00018
Measure Title	Password: Length
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.14 MSM-GSS-0006 – 2.4.8
Background	The minimum password length for any user password is 8 characters.
Measure	Minimum Password Length.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies>Password Policy\" 2) Choose "Minimum Password Length" and set it to the value provided below. Value: 8 characters or more
Exception	
First appearance	19-05-2014

Measure ID	3SW00020
Measure Title	Remote Admin: Saved Passwords
Classification	CRITICAL
Baseline Reference	No security baseline reference
Background	For all Remote Desktop Connection sessions, it is not permissible to save passwords for the session.
Measure	Remote Desktop Services\Remote Desktop Connection Client: Do not allow passwords to be saved.

Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Policies\Administrative Templates\Windows Components\Terminal Services\Remote Desktop Connection Client" 2) Choose "Do not allow passwords to be saved" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00021
Measure Title	Remote Admin: Minimum NTLM Security
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.1.3 MSM-GSS-0006 – 2.4.8
Background	Ensure the most reasonable authentication protocols and encryption methods are used for Remote Administration sessions. Older protocols are deemed insecure.
Measure	Network Security: Minimum session security for NTLM SSP based (including secure RPC) clients.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Network security: Minimum session security for NTLM SSP based (including secure RPC) clients" and set it to the value provided below. Value: Require NTLMv2 session security and require 128-bit encryption or greater.
Exception	
First appearance	19-05-2014

Measure ID	3SW00022
Measure Title	Remote Admin: Session Encryption
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.1.3 MSM-GSS-0006 – 2.4.8
Background	Ensure strong encryption is always requested from the host server.
Measure	Strong encryption will be used for remote access to servers.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Policies\Administrative Templates\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Security" 2) Choose "Encryption Level" and set it to the value provided below. Value: Set client connect encryption level to "High Level".
Exception	

First appearance	19-05-2014
Measure ID	2SW00023
Measure Title	Remote Admin: Session Idle
Classification	MODERATE
Baseline Reference	No security baseline reference
Background	If a Remote Administration session is established, yet remains idle for a certain period of time, terminate the Remote Administration session.
Measure	Remote Desktop Services\Remote Desktop Session Host\Session Time Limits: Set time limit for active but idle Remote Desktop Services sessions
Implementation	1) Start MMC and browse to the following location, "User Configuration\Policies\Administrative Templates\Windows Components\Terminal Services\Terminal Server\Session Time Limits" 2) Choose "Set time limit for active but idle Remote Desktop Services sessions" and set it to the value provided below. Value: 15 minutes or less
Exception	
First appearance	19-05-2014

3.2 Network Security

Measure ID	3SW00024
Measure Title	Logon/Logoff: Disconnect on Logon Hours Expiry
Classification	CRITICAL
Baseline Reference	No security baseline reference
Background	When login hours expire, disconnect client.
Measure	Microsoft Network Server: Disconnect clients when logon hours expire.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Microsoft network server: Disconnect clients when logon hours expire" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00025
Measure Title	Password: Encryption to 3 rd Party SMB Servers
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.12 MSM-GSS-0006 – 2.4.8
Background	Allow sending unencrypted passwords to 3 rd Party SMB Servers.

Measure	Microsoft Network Client: Send unencrypted password to third-party SMB servers
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Microsoft Network Client: Send unencrypted password to third party SMB servers" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00026
Measure Title	Service Configuration: ICMP Redirects/Broadcasts
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Managed endpoints shall be configured to prevent ICMP redirects
Measure	MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes
Implementation	1) Open registry and browse to the following key "HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\" 2) Create or modify the "EnabledICMPRedirect" sub-key, and set it to the value provided below Value: "0" must be configured in the sub-key to completely disable it
Exception	
First appearance	19-05-2014

Measure ID	3SW00027
Measure Title	Service Configuration: IRDP configuration
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Managed endpoints shall not run Internet Router Discovery Protocol (IRDP).
Measure	MSS: (PerformRouterDiscover) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS).
Implementation	1) Open registry and browse to the following key "HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\" 2) Create or modify the "PerformRouterDiscovery" sub-key and set it to the value provided below. Value: "0" must be configured in the sub-key to completely disable it
Exception	
First appearance	19-05-2014

Measure ID	3SW00028
Measure Title	Disable Source Routing for Ipv4 and Ipv6
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Managed endpoints shall not run routing protocols.
Measure	MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)
Implementation	1) Open registry and browse to the following key "HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\" 2) Create or modify the "DisableIPSourceRouting" sub-key, and set it to the value provided below Value: "2" must be configured in the sub-key to completely disable it
Exception	
First appearance	19-05-2014

Measure ID	3SW00029
Measure Title	Domain Member: Digitally encrypt or sign secure channel data
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Always digitally encrypt or sign Domain Member sessions
Measure	Domain Member: Digitally encrypt or sign secure channel data
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Domain Member: Digitally encrypt or sign secure channel data (always)" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00030
Measure Title	Windows: Network Client Certificate Signature
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Always sign Microsoft Network Client Certificate.
Measure	Microsoft Network Client: Digitally sign communications
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\"

	2) Choose "Microsoft Network Client: Digitally sign communications (always)" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	2SW00031
Measure Title	Windows: Domain Member Encryption
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Digitally encrypt Domain Member sessions.
Measure	Domain Member: Digitally encrypt secure channel data.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\ 2) Choose "Domain Member: Digitally encrypt secure channel data (when possible)" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	2SW00032
Measure Title	Windows: Sign Domain Member sessions
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Digitally sign Domain Member sessions.
Measure	Domain Member: Digitally sign secure channel data.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\ 2) Choose "Domain Member: Digitally sign secure channel data (when possible)" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00033
Measure Title	Windows: Domain Member Session Key Strength
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8

Background	Require Strong Session Key for Domain Members
Measure	Domain member: Require strong (Windows 2000 or later) session key
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\ 2) Choose "Domain member: Require strong (Windows 2000 or later) session key" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00076
Measure Title	Service Hardening: SNMP Community Names
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Public and Private SNMP Community Strings must be changed prior to a network device being installed on the network. No default community strings are permitted.
Measure	The community strings "public" and "private" must be changed
Implementation	Check SNMP configuration file to ensure "public" and "private" are not being used as community names.
Exception	Default Atos policy states that SNMP shall not be used. However, if an exception is granted, this control must be checked.
First appearance	19-05-2014

Measure ID	3SW00077
Measure Title	Server Hardening: disabling SMB1
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	There are a number of vulnerabilities in SMB version 1 some of these have already been exploited and several other vulnerabilities have known attack vectors.
Measure	Disable or remove SMB1 on Windows server running 2012 or above.
Implementation	There is following option for removal of the SMB1 feature PowerShell 2012 and above Get-WindowsFeature FS-SMB1 Disable-WindowsOptionalFeature -Online -FeatureName smb1protocol ----- Microsoft Ref: https://support.microsoft.com/en-gb/help/2696547/how-to-enable-and-disable-smbv1-smbv2-and-smbv3-in-windows-and-windows
Exception	
First appearance	24-07-2017

Measure ID	3SW00083						
Measure Title	Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2 & above						
Classification	CRITICAL						
Baseline Reference	No Baseline Reference						
Background	SSLv3, TLS v 1.0, 1.1 are insecure and need to be disabled and TLS v 1.2 & above to be enabled						
Measure	Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2 & above						
Implementation	To disable SSL3.0,TLS 1.0 and 1.1 on windows server through registry editor; Registry path: HKLM SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols To disable SSL 3.0 by default, create a DisabledByDefault entry and change the DWORD value to 1 Or change the DWORD value of Enabled to 0. To disable TLS1.0 by default, create a DisabledByDefault entry and change the DWORD value to 1 Or change the DWORD value of Enabled to 0. To disable TLS1.1 by default, create a DisabledByDefault entry and change the DWORD value to 1 Or change the DWORD value of Enabled to 0. To Enable TLS1.2; create an Enabled entry in either the Client or Server subkey, as given in the table below TLS 1.2 subkey table <table border="1"> <thead> <tr> <th>Subkey</th><th>Description</th></tr> </thead> <tbody> <tr> <td>Client</td><td>Controls the use of TLS 1.2 on the TLS client.</td></tr> <tr> <td>Server</td><td>Controls the use of TLS 1.2 on the TLS server.</td></tr> </tbody> </table> . This entry does not exist in the registry by default. After you have created the entry, change the DWORD value to 1. https://docs.microsoft.com/en-us/windows-server/security/tls/tls-registry-settings	Subkey	Description	Client	Controls the use of TLS 1.2 on the TLS client.	Server	Controls the use of TLS 1.2 on the TLS server.
Subkey	Description						
Client	Controls the use of TLS 1.2 on the TLS client.						
Server	Controls the use of TLS 1.2 on the TLS server.						
Exception	As per application dependencies (to be marked as risk)						
First appearance	12-08-2020						

Measure ID	3SW00087
------------	----------

Measure Title	Disable weak hashing algorithms
Classification	CRITICAL
Baseline Reference	No Baseline reference
Background	Cipher Suites in TLS/SSL (Schannel SSP)
Measure	Disabled Weak hashing algorithms MD5 and SHA 1
Implementation	To disable MD5 and SHA1 hash algorithms, add and set the following DWORD keys in registry as below: 1) HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\MD5 Keep value '0' for Enabled key. 2) HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Hashes\SHA Keep value '0' for Enabled key. Note: Enabled = 0 it means MD5 and SHA1 algorithms are disabled in Windows Server. Ref. Link.
Exception	
First appearance	24-06-2021

3.3 Operation Security

Measure ID	3SW00034
Measure Title	Idle Login Activity
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Idle remote logins will be terminated after 15 minutes or less.
Measure	Interactive Logon: Machine inactivity limit.
Implementation	For Windows 2012 also perform the following: 1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Interactive Logon: Machine inactivity limit" and set it to the value provided just below. Value: 900 seconds or less (but more than 0)
Exception	
First appearance	19-05-2014

Measure ID	3SW00035
Measure Title	Internet Connection Sharing must be disabled
Classification	CRITICAL

Baseline Reference	No reference to Security Baseline
Background	Internet Connectivity Share must be disabled.
Measure	Internet Connection Sharing (ICS).
Implementation	1)Open Group Policy Management Editor. To do so, click Start, and then in the Start Search box, type mmc gpedit.msc. 2)In the navigation pane, open the following folders: Local Computer Policy, Computer Configuration, Administrative Templates, Network, and Network Connections. 3)In the details pane, double-click "Prohibit use of Internet Connection Sharing on your DNS domain network." 4)Set it to the value provided below. 5)Click OK to save your changes. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00036
Measure Title	Disable automatic logon of Administrator accounts
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Automatic login of Administrator account must be disabled.
Measure	MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)
Implementation	1) Open registry and browse to the following key "HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\" 2) Create or modify the "MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)" sub-key, and set it to the value provided below Value: "0" must be configured in the sub-key, which prevents automatic logon of administrators.
Exception	
First appearance	19-05-2014

Measure ID	3SW00037
Measure Title	Removable Devices
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Only locally logged-on users are allowed to use access the floppy drive.
Measure	Devices: Restrict floppy access to locally logged-on user only
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Devices: Restrict floppy access to locally logged-on user only" and set it to the value provided below. Value: Enabled

Exception	
First appearance	19-05-2014

Measure ID	3SW00038
Measure Title	Screen Saver: Enabled
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	On Windows servers, the screen saver must be enabled.
Measure	Control Panel\Personalization: Enable screen saver.
Implementation	1) Start MMC and browse to the following location, "User Configuration\Administrative Templates\Control Panel\Personalization" 2) Choose "Enable Screen Saver" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00039
Measure Title	Screen Saver: Password Protected
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	On Windows servers, the screen saver must be password protected.
Measure	"Control Panel\Personalization: Password protect the screen saver".
Implementation	1) Start MMC and browse to the following location, "User Configuration\Administrative Templates\Control Panel\Personalization" 2) Choose "Password protect the screen saver" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00040
Measure Title	Screen Saver: Activation after idle time
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	The screen saver must activate after no more than 15 minutes of inactivity.
Measure	Control Panel\Personalization: Screen saver timeout

Implementation	1) Start MMC and browse to the following location, "User Configuration\Administrative Templates\Control Panel\Personalization" 2) Choose "Screen saver timeout" and set it to the value provided below. Value: 15 minutes or less (but more than 0)
Exception	
First appearance	19-05-2014

Measure ID	2SW00041
Measure Title	Server Configuration: Removable Media Access
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	User access to removable media.
Measure	Devices: Restrict CD-ROM access to locally logged-on user only
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Devices: Restrict CD-ROM access to locally logged-on user only" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00042
Measure Title	Windows: Anonymous enumeration of SAM
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Anonymous enumeration of SAM accounts is not permitted.
Measure	Network Access: Do not allow anonymous enumeration of SAM accounts.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Network access: Do not allow anonymous enumeration of SAM accounts" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00043
Measure Title	Windows: Anonymous enumeration of SAM and Shares

Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Anonymous enumeration of SAM accounts and shares is not permitted.
Measure	Network Access: Do not allow anonymous enumeration of SAM accounts and shares
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Do not allow anonymous enumeration of SAM accounts and shares" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00044
Measure Title	Windows: Anonymous SID/NAME translation
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Anonymous SID/NAME attribute requests for another user are not allowed.
Measure	Network Access: Allow anonymous SID/NAME translation.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Allow anonymous SID/NAME translation" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	2SW00045
Measure Title	Windows: Cached Credentials for Network authentication
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Cached credentials are allowed for Windows Servers.
Measure	Network Access: Do not allow storage of passwords and credentials for network authentication.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Do not allow storage of passwords and credentials for network authentication" and set it to the value provided below. Value: Disabled

Exception	
First appearance	19-05-2014

Measure ID	2SW00046
Measure Title	Windows: FIPS encryption
Classification	MODERATE
Baseline Reference	No reference to Security Baseline
Background	FIPS-compliant encryption algorithms are not required for system cryptography.
Measure	System Cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "System Cryptography: Use FIPS compliant algorithms for encryption, hashing, and signing" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	2SW00047
Measure Title	Windows: Forced Logoff at Timer expiry
Classification	MODERATE
Baseline Reference	No security baseline reference
Background	For Windows servers, if hours expire, logoff will not be forced.
Measure	Network security: Do not enforce Forced logoff when logon hours are not defined for users.
Implementation	Source : https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-force-logoff-when-logon-hours-expire 1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network security: Force logoff when logon hours expire" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00048
Measure Title	Windows: Sharing and Security for Local Accounts

Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.1 MSM-GSS-0006 – 2.4.8
Background	If local accounts are required, each user must have their own local account. Guest account cannot be used.
Measure	Network Access: Sharing and security model for local accounts.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Sharing and security model for local accounts" and set it to the value provided below. Value: "Classic – local users authenticate as themselves".
Exception	
First appearance	19-05-2014

Measure ID	3SW00049
Measure Title	Windows: List of Anonymous Shares
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	List of shares which can be accessed anonymously.
Measure	Network Access: Shares that can be accessed anonymously.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Shares that can be accessed anonymously" and set it to the value provided below. Value: Ensure that it is left blank/empty
Exception	
First appearance	19-05-2014

Measure ID	3SW00050
Measure Title	Windows: Case-insensitivity for Win32 compatibility
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Non-Windows subsystems must support case insensitivity to be compatible with Win32 subsystem.
Measure	System Objects: Require case insensitivity for non-Windows subsystems.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "System Objects: Require case insensitivity for non-Windows subsystems" and set it to the value provided below. Value: Enabled

Exception	
First appearance	19-05-2014

Measure ID	3SW00051
Measure Title	Windows: Prevent Anonymous named-pipe access
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	On Windows Servers, anonymous access to named pipes must be restricted.
Measure	Network Access: Restrict anonymous access to Named Pipes and Shares.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Restrict anonymous access to Named Pipes and Shares" and set it to the value provided below. Value: Enabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00052
Measure Title	Windows: Remote Registry Path and Sub-path restrictions
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Remotely accessible registry paths and sub-paths must be restricted.
Measure	Network Access: Remotely accessible registry paths and sub-paths.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\" 2) Choose "Network Access: Remotely accessible registry paths and subpaths" and set it to the value provided below. The registry paths defined in the control are allowed. Fewer paths can be defined without negatively affecting the compliance of the control. Value: "System\CurrentControlSet\Control\Print\Printers" "System\CurrentControlSet\Services\Eventlog" "Software\Microsoft\OLAP Server" "Software\Microsoft\Windows NT\CurrentVersion\Print" "Software\Microsoft\Windows NT\CurrentVersion\Windows" "System\CurrentControlSet\Control\ContentIndex" "System\CurrentControlSet\Control\Terminal Server" "System\CurrentControlSet\Control\Terminal Server\UserConfig" "System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration"

	"Software\Microsoft\Windows NT\CurrentVersion\Perflib" "System\CurrentControlSet\Services\SysmonLog" "System\CurrentControlSet\Services\CertSvc"
Exception	
First appearance	19-05-2014

Measure ID	3SW00053
Measure Title	Windows: Remote Registry Path restrictions
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	Remotely accessible registry paths must be restricted.
Measure	Network Access: Remotely accessible registry paths.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Network Access: Remotely accessible registry paths" and set it to the value provided below. The registry paths defined in the control are allowed. Fewer paths can be defined without negatively affecting the compliance of the control. Value: "System\CurrentControlSet\Control\ProductOptions" "System\CurrentControlSet\Control\Server Applications" "Software\Microsoft\Windows NT\CurrentVersion"
Exception	
First appearance	19-05-2014

Measure ID	2SW00054
Measure Title	Windows: Shutdown if logging problem
Classification	MODERATE
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	The system must shut down if it is unable to log data to the security log.
Measure	Audit: Shut down system immediately if unable to log security audits.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Audit: Shut down system immediately if unable to log security audits" and set it to the value provided below. Value: Disabled
Exception	
First appearance	19-05-2014

Measure ID	3SW00055
Measure Title	Windows: List of Anonymous named pipes
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	The named pipes which can be accessed anonymously must be blank.
Measure	Network Access: Named Pipes that can be accessed anonymously.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Network Access: Named Pipes that can be accessed anonymously" and set it to the value provided below. Value: Ensure that it is left blank/empty
Exception	
First appearance	19-05-2014

Measure ID	3SW00056
Measure Title	Windows: Screen Saver Start Delay
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	There must be no delay in starting the screen saver once requested.
Measure	MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires.
Implementation	1) Open registry and browse to the following key "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon" 2) Create or modify the "ScreenSaverGracePeriod" sub-key, and set it to the value provided below Value: 0
Exception	
First appearance	19-05-2014

Measure ID	3SW00057
Measure Title	Windows Anonymous equivalency to "Everyone"
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.4.8
Background	User "Anonymous" is not allowed to have privileges of group "Everyone".
Measure	Network Access: Let Everyone permissions apply to anonymous users.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options" 2) Choose "Network Access: Let Everyone permissions apply to anonymous users" and set it to the value provided below. Value: Disabled

Exception	
First appearance	19-05-2014

Measure ID	3SW00058
Measure Title	Ensure NTP Client is started on all Windows Computers
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.3.2
Background	All computers must synchronize time with a reliable clock source. The "Windows Time Service" (w32time) service must be started on all computers.
Measure	Ensure the "w32time" service is started on all computers.
Implementation	Browse to the Local Services in MMC and ensure the "Windows Time Service" is started and configured to start automatically.
Exception	
First appearance	19-05-2014

Measure ID	3SW00084
Measure Title	AppLocker usage and check for any executable files from Public Folders
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Create a check for any executable files from Public Folders and policy for AppLocker usage.
Measure	Windows AppLocker Policy
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Application Control Policies\AppLocker, the Windows AppLocker settings exist 2) Select "Configure Enforcement Rule" and Use the enforcement setting for each collection to configure to Enforce rules, rules are enforced for the rule collection and all events are audited. 3) Select the Configured check box for the rule collection that you are editing, and then verify that Enforce rules are selected. Click OK. 4) Open the Advanced tab and enable the DLL rule collection. Ref. Link
Exception	
First appearance	04-05-2021

Measure ID	3SW00085
Measure Title	Check all executable files in vulnerable locations
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Check all executable files in vulnerable locations Public Folders.
Measure	Software Restriction Policies
Implementation	Open gpedit.msc

	1. Go to User Configuration > Policies > Windows Settings > Security Settings > Software Restriction Policies. 2. Click Additional Rules to view the default file paths configured to allow programs running under paths specified by the SystemRoot and ProgramFiles environment variables. 3. To add a new path rule, right-click the Additional Rules folder and select New Path Rule. 4. In the New Path Rule dialog box, specify a path or click Browse to select a path and file type like .exe .vbs From the Security level drop-down menu, select Disallowed Enter a suitable description. Click OK. By adding this rule, all programs in the specified path will be block.
Exception	
First appearance	11-06-2021
Measure ID	3SW00086
Measure Title	Protection against literal movement (wigest)
Classification	MODERATE
Baseline Reference	No security baseline reference
Background	
Measure	Protection against literal movement (wigest) Literal movement (Wigest) is abused by e.g. TRICKBOT
Implementation	1) Open registry and browse to the following registry key HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\ 2) Create or modify the "UseLogonCredentials" sub-key and set it to the value provided below. Value: "0" must be configured in the sub-key.
Exception	
First appearance	07-06-2021

3.4 Logging

Measure ID	2SW00060
Measure Title	Logging: Logon Success
Classification	MODERATE
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	Determine whether audit events on credentials for user account logon requests are generated.
Description	Logon events credential validation shall be logged.
Measure	Account Logon: Credential Validation.
Implementation	Under "Advanced Security Audit Policy->Account Logon", set Credential Validation for at least = "Success". This will enable the 4774, 4775, 4776, and 4777 Event IDs, from which login requests can be audited.
Exception	
First appearance	17-04-2014

Measure ID	3SW00061
Measure Title	Logging: Unsuccessful Logins
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	In order to be able to audit for unsuccessful logins, events must be logged and retained for enough time to review the logs.
Description	Unsuccessful login attempts must be retained for a specified period of time.
Measure	Unsuccessful login attempts for 7 days.
Implementation	Retain Unsuccessful login attempts for 7 days or more.
Exception	
First appearance	17-04-2014

Measure ID	3SW00062
Measure Title	Logging of Logoff attempts
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	Reports when a user logs off from the system
Description	Log successful logon and logoff attempts.
Measure	Logon/Logoff: Logoff.
Implementation	Using “auditpol”, script the “Logon/Logoff – Logoff” audit subcategory (to at least) = “Success”.
Exception	
First appearance	17-04-2014

Measure ID	3SW00063
Measure Title	Logging of Logon attempts
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	In order to audit for logon attempts, both successful and unsuccessful logon events need to be logged.
Description	Log unsuccessful and successful logon attempts.
Measure	Logon/Logoff: Logon.
Implementation	Using “auditpol”, script the “Logon/Logoff – Logon” audit subcategory to = “Success and Failure”
Exception	
First appearance	17-04-2014

Measure ID	3SW00064
Measure Title	Logging of Computer Account Management
Classification	CRITICAL

Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	Each event related to account management must be tracked (creation, change, delete, rename, enable/disable, password updates).
Description	Successful computer account management events will be logged
Measure	Account Management: Computer Account Management
Implementation	Using "auditpol", script the "Account Management – Computer Account Management" audit subcategory to (at least) = "Success"
Exception	
First appearance	17-04-2014

Measure ID	3SW00065
Measure Title	Logging of Other Account Management events
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When password-related information is accessed, such as the password hash, or when the password policy API is called, related events must be logged.
Description	Successful non-computer account management events will be logged
Measure	Account Management: Other Account Management Events
Implementation	Using "auditpol", script the "User Account Management – Other Account Management Events" audit subcategory to at least = "Success". This will enable the 4782 and 4793 Event IDs.
Exception	
First appearance	17-04-2014

Measure ID	3SW00066
Measure Title	Logging of Security Group Management
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When security groups are created or modified, related events must be logged.
Description	Successful security group management events will be logged
Measure	Account Management: Security Group Management
Implementation	Using "auditpol", script the "User Account Management – Security Group Management" audit subcategory to (at least) = "Success". This will enable the 4727-4735, 4737, 4754-4758, 4764 Event IDs.
Exception	
First appearance	17-04-2014

Measure ID	3SW00067
Measure Title	Logging of User Account Management
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When user accounts (or groups) are created, changed (renamed, disabled/enabled), or when a password is set or changed, related events must be logged.
Description	Successful user account management event will be logged
Measure	Account Management: User Account Management
Implementation	Using "auditpol", script the "Account Management – User Account Management" audit subcategory to (at least) = "Success". This enables approximately 50 Event IDs, which can be enumerated on technet.
Exception	
First appearance	17-04-2014

Measure ID	3SW00068
Measure Title	Logging of Special logons
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	"Special logons", or logons of accounts with administrative privileges, must be logged.
Description	Successful "special login" events shall be logged
Measure	Logon/Logoff: Special Logon
Implementation	Using "auditpol", script the "Logon/Logoff – Special Logon" audit subcategory to at least = "Success"
Exception	
First appearance	17-04-2014

Measure ID	3SW00069
Measure Title	Logging of Audit Policy Changes
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When a change to user rights, or audit or trust policies occurs, related events must be logged.
Description	Success and Failure events related to Audit Policy Change are logged
Measure	Policy Change: Audit Policy Change
Implementation	Using "auditpol", script the "Policy Change – Audit Policy Change" audit subcategory to = "Success and Failure". This will enable Event IDs 608-623, 625, 768, 769, 770, 771, 805.
Exception	

First appearance	17-04-2014
------------------	------------

Measure ID	3SW00070
Measure Title	Logging of Authentication Policy Changes
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When changes to any authentication policy are made, the respective events must be logged. This can include trust relationship changes, Kerberos policy changes, special rights being granted to a user, and domain namespace conflicts.
Description	Successful events related to Authentication Policy Change are logged
Measure	Policy Change: Authentication Policy Change
Implementation	Using "auditpol", script the "Policy Change – Authentication Policy Change" audit subcategory to at least = "Success"
Exception	
First appearance	17-04-2014

Measure ID	3SW00071
Measure Title	Logging of Use of Sensitive Privilege
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When creation and modification of "sensitive privilege" (user rights) occurs, related events must be logged to allow auditing.
Description	Success and Failure of Sensitive Privilege use events are logged
Measure	Privilege Use: Sensitive Privilege Use
Implementation	Under "Advanced Security Audit Policy->Privilege Use", set: Audit Sensitive Privilege Use" = "Success and Failure". This will enable the 4672, 4673, and 4674 Event IDs, from which "access requests for user rights" can be audited.
Exception	
First appearance	17-04-2014

Measure ID	3SW00072
Measure Title	Logging of Security State Change
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When events related to the security state of a server occur, they must be logged.
Description	Success and failure events related to "Security State Change" must be logged.
Measure	System: Security State Change
Implementation	Under "Security Auditing->Advanced Security Audit Policy Settings", set: Audit Security State Change" = "Success and Failure".

	This will enable the 4608 (windows start), 4609 (windows shutdown), 4616 (time change), and 4621 (recovered from CrashOnAuditFail event) Event IDs, from which "system security state change" can be audited.
Exception	
First appearance	17-04-2014

Measure ID	3SW00073
Measure Title	Logging of "Security System Extension" events
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 – 2.6.5
Background	When extensions to system security are activated, such as an authentication package or when a service is installed, related system events must be logged.
Description	Success and Failure events related to Security System Extension must be logged.
Measure	System: Security System Extension
Implementation	Under "Security Auditing->Advanced Security Audit Policy Settings", set: Audit Security System Extension" = "Success and Failure". This will enable the 4610, 4611, 4614, 4622, and 4697 Event IDs, from which "security system extension" state can be audited.
Exception	
First appearance	17-04-2014

Measure ID	3SW00074
Measure Title	User Password: Age Minimum
Classification	CRITICAL
Baseline Reference	No Baseline reference
Background	Passwords MUST have a validity period of no less than 1 day.
Measure	Minimum Password Age.
Implementation	1) Start MMC and browse to the following location, "Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\ 2) Set the attribute to the value provided below. 3) Click OK. Value: 30 days
Exception	
First appearance	02-12-2016

Measure ID	3SW00082
Measure Title	Windows: Create a token object user right must not be assigned to any groups or accounts
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline

Background	Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities https://www.microsoft.com/en-us/download/details.aspx?id=55319
Measure	The "Create a token object" user right allows a process to create an access token. This could be used to provide elevated rights and compromise a system
Implementation	Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> User Rights Assignment >> "Create a token object" to be defined but containing no entries https://www.microsoft.com/en-us/download/details.aspx?id=55319
Exception	For domain controllers and standalone systems, this is NA
First appearance	19-04-2017

3.5 Non-Alcatraz Measures

Below measures are highly recommended if possible, to implement but not scanned automatically by scanner

Measure ID	3SW00019
Measure Title	Service Hardening: Secure Built-in Remote Management Interface
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.5
Background	All default vendor passwords on remote management interfaces must be changed.
Measure	Appropriately secure built-in remote management interfaces.
Implementation	Change default passwords of admin interfaces (ILO, SSH, etc).
Exception	
First appearance	19-05-2014

Measure ID	3SW00059
Measure Title	Ensure NTP clock does not drift significantly from a trusted time source.
Classification	CRITICAL
Baseline Reference	MSM-GSS-0006 – 2.3.2
Background	Monitor clock of Windows Computer to ensure it does not drift too far from a trusted time source. The agreed maximum drift is set to 300 seconds
Measure	Use monitoring tooling to collect Windows Computer local time and compare it to a trusted time source.
Implementation	Enable "time skew" monitoring with tools Nagios or SCOM.
Exception	
First appearance	19-05-2014

Measure ID	3SW00075
Measure Title	Administrator and Service Account Password: Length
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.25, 2.1.14 MSM-GSS-0006 – 2.4.8
Background	To Improve the Security of Authentication in an AD DS Domain for Administrator and service account must have meet password Complexity policy
Measure	The minimum password length for any Administrator or service account password is 15 characters.
Implementation	For Windows 2012 and above apply fine grained password policies to ensure Administrator and Service accounts are 15 characters or more: 2012/2012R2/2016 and 2019 https://blogs.technet.microsoft.com/canitpro/2013/05/29/step-by-step-enabling-and-using-fine-grained-password-policies-in-ad/
Exception	Not applicable to 2003R2 and below versions of Windows
First appearance	02-12-2016

Measure ID	3SW00078
Measure Title	Virus Protection
Classification	CRITICAL
Baseline Reference	MSM-GSS-0001 2.6.3
Background	Virus protection must be deployed, and signatures updated regularly on all applicable Windows hosts.
Measure	Check that virus protection is deployed and up to date.
Implementation	Confirm that antivirus software has been deployed and is up to date and configured for automatic updated. Usually this is the McAfee Endpoint Security Agent. The agent should be installed, and the service must be running. The update of the patterns is done via the infrastructure. E.g.: sc query find "masvc" For custom antivirus agents, a separate agreement must be created for the check
Exception	
First appearance	16-05-2019

Measure ID	3SW00079
Measure Title	PIN: Complexity
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.6, 2.1.17, 2.1.18 MSM-GSS-0006 – 2.4.8
Background	Ensure PIN complexity is enabled.
Measure	PIN must meet complexity requirements.
Implementation	In several cases a user password can't be used and a PIN (Personal Identification Number) is used instead. 1) Start MMC and browse to the following location, "Computer Configuration\Policies\Administrative Templates\System\PIN Complexity"

	2) Choose the following policies and set it to the value provided: "PIN History" = 5 or more "Minimum PIN length " = 4
Exception	
First appearance	19-05-2014

Measure ID	3SW00080
Measure Title	Service Account – Maximum Age
Classification	CRITICAL
Baseline Reference	MSM-GSS-0002 – 2.1.26 MSM-GSS-0006 – 2.4.8
Background	Maximum age for Service Account configured maximum for 1 year (365 days)
Measure	Maximum Age for Service Account – 365 days
Implementation	If "Fine Grained Password Policy (FGPP)" is in place, then for Service Account a maximum password age 365 days is required. The validation of this rule cannot be done locally
Exception	
First appearance	22-07-2019

Measure ID	3SW00081
Measure Title	Windows: Domain Member must be running Credential Guard
Classification	CRITICAL
Baseline Reference	No reference to Security Baseline
Background	Credential Guard uses virtualization-based security to protect data that could be used in credential theft attacks if compromised. https://docs.microsoft.com/en-us/windows/security/identity-protection/credential-guard/credential-guard-manage
Measure	This authentication information, which was stored in the Local Security Authority (LSA) in previous versions of Windows, is isolated from the rest of operating system and can only be accessed by privileged system software.
Implementation	1) Configure the policy value for Computer Configuration >> Administrative Templates >> System >> Device Guard >> 2) Double-click Turn On Virtualization Based Security, and then click the Enabled option. 3) In the Select Platform Security Level box, choose Secure Boot or Secure Boot and DMA Protection. 4) In the Credential Guard Configuration box, click Enabled with UEFI lock, and then click OK. If you want to be able to turn off Windows Defender Credential Guard remotely, choose Enabled without lock. https://docs.microsoft.com/en-us/windows/security/identity-protection/credential-guard/credential-guard-manage
Exception	For domain controllers and standalone systems, this is NA
First appearance	17-08-2017

Appendix A Checklist

Device Name	
-------------	--

Measure ID	Measure title	Alcatraz	Checked
3SW00001	Authorization: Administrative Delegation	YES	
3SW00002	Authorization: Impersonation of Client	YES	
3SW00003	Authorization: Server Shutdown	YES	
3SW00004	Login: LDAP Client Signing	YES	
3SW00005	Login: Only Allow Local Console Access to Administrators	YES	
3SW00006	Password: Age	YES	
3SW00007	User Password: Age Maximum	YES	
2SW00008	Password: Cached Credentials	YES	
3SW00009	Password: Changes for Machine Account	YES	
3SW00010	Password: Complexity	YES	
3SW00011	Password: Domain Authentication	YES	
3SW00012	Password: Encryption	YES	
3SW00013	Password: Failure Lockout Duration	YES	
3SW00014	Password: Failure Threshold	YES	
3SW00015	Password: Failure Timer	YES	
3SW00016	Password Retention History	YES	
3SW00017	Password: LAN Manager Hash Storage	YES	
3SW00018	Password: Length	YES	
3SW00019	Service Hardening: Secure Built-in Remote Management Interface	NO	
3SW00020	Remote Admin: Saved Passwords	YES	
3SW00021	Remote Admin: Minimum NTLM Security	YES	
3SW00022	Remote Admin: Session Encryption	YES	
2SW00023	Remote Admin: Session Idle	YES	
3SW00024	Logon/Logoff: Disconnect on Logon Hours Expiry	YES	
3SW00025	Password: Encryption to 3rd Party SMB Servers	YES	
3SW00026	Service Configuration: ICMP Redirects/Broadcasts	YES	
3SW00027	Service Configuration: IRDP configuration	YES	
3SW00028	Disable Source Routing for IPv4 and IPv6	YES	
3SW00029	Windows: Domain Member Encryption	YES	
3SW00030	Windows: Network Client Certificate Signature	YES	
2SW00031	Windows: Domain Member Encryption	YES	
2SW00032	Windows: Sign Domain Member sessions	YES	

Measure ID	Measure title	Alcatraz	Checked
3SW00033	Windows: Domain Member Session Key Strength	YES	
3SW00034	Idle Login Activity	YES	
3SW00035	Internet Connection Sharing must be disabled	YES	
3SW00036	Disable automatic logon of Administrator accounts	YES	
3SW00037	Removable Devices	YES	
3SW00038	Screen Saver: Enabled	YES	
3SW00039	Screen Saver: Password Protected	YES	
3SW00040	Screen Saver: Activation after idle time	YES	
2SW00041	Server Configuration: Removable Media Access	YES	
3SW00042	Windows: Anonymous enumeration of SAM	YES	
3SW00043	Windows: Anonymous enumeration of SAM and Shares	YES	
3SW00044	Windows: Anonymous SID/NAME translation	YES	
2SW00045	Windows: Cached Credentials for Network authentication	YES	
2SW00046	Windows: FIPS encryption	YES	
2SW00047	Windows: Forced Logoff at Timer expiry	YES	
3SW00048	Windows: Sharing and Security for Local Accounts	YES	
3SW00049	Windows: List of Anonymous Shares	YES	
3SW00050	Windows: Case-insensitivity for Win32 compatibility	YES	
3SW00051	Windows: Prevent Anonymous named-pipe access	YES	
3SW00052	Windows: Remote Registry Path and Sub-path restrictions	YES	
3SW00053	Windows: Remote Registry Path restrictions	YES	
2SW00054	Windows: Shutdown if logging problem	YES	
3SW00055	Windows: List of Anonymous named pipes	YES	
3SW00056	Windows: Screen Saver Start Delay	YES	
3SW00057	Windows Anonymous equivalency to "Everyone"	YES	
3SW00058	Ensure NTP Client is started on all Windows Computers	YES	
3SW00059	Ensure NTP clock does not drift significantly from a trusted time source.	NO	
2SW00060	Logging: Logon Success	YES	
3SW00061	Logging: Unsuccessful Logins	YES	
3SW00062	Logging of Logoff attempts	YES	
3SW00063	Logging of Logon attempts	YES	
3SW00064	Logging of Computer Account Management	YES	
3SW00065	Logging of Other Account Management events	YES	

Measure ID	Measure title	Alcatraz	Checked
3SW00066	Logging of Security Group Management	YES	
3SW00067	Logging of User Account Management	YES	
3SW00068	Logging of Special logons	YES	
3SW00069	Logging of Audit Policy Changes	YES	
3SW00070	Logging of Authentication Policy Changes	YES	
3SW00071	Logging of Use of Sensitive Privilege	YES	
3SW00072	Logging of Security State Change	YES	
3SW00073	Logging of "Security System Extension" events	YES	
3SW00074	User Password: Age Minimum	YES	
3SW00075	Administrator and Service Account Password: Length	NO	
3SW00076	Service Hardening: SNMP Community Names	YES	
3SW00077	Server Hardening: disabling SMB1	YES	
3SW00078	Virus Protection	NO	
3SW00079	PIN: Complexity	NO	
3SW00080	Service Account – Maximum Age	NO	
3SW00081	Windows: Domain Member must be running Credential Guard	NO	
3SW00082	Windows: Create a token object user right must not be assigned to any groups or accounts	YES	
3SW00083	Disable SSLv3, TLSv1.0, TLSv1.1 and enable TLSv1.2 & above	YES	
3SW00084	AppLocker usage and check for any executable files from Public Folders	NO	